관리적 보안 운영

KOREA
코리아IT아카데미학원



class	정보보안 산업기사 취득과정 A
name	조채언

목 차

Ⅰ. 정보 보호 관리 체계 구축 5단계 ····· 3

Ⅱ. 정보 보호 교육 계획 수립 및 보고 방법 ····· 4

가. 정보보호 계획 수립 ····· 4

나. 정보보호 교육 계획 보고 ····· 5

Ⅲ. 연간 정보 교육 수행 계획서 ····· 6

Ⅳ. 교육 결과서 작성 ····· 7

Ⅴ. 정보 보호 점검 계획서 목차 작성 ····· 9

Ⅵ. 정보보호 취약점 점검 및 공격기법 분석과 대응방안 ····· 11

가. 정보 보호 취약 요인 사례 ····· 11

나. 정보보호 점검 항목 ····· 12

다. 정보보호 점검 체크리스트 점검 결과 ····· 14

라. XSS 취약점 공격기법 및 대응방안 ····· 15

Ⅶ. 정보보호 침해사고 대응 및 개인정보 주체 통보 방법 ····· 17

가. 침해 사고 대응 절차 ····· 17

나. 대응 기관 ····· 17

다. 개인정보 정보주체에게 유출사고를 통보하는 방법 ····· 18

Ⅷ. 정보보호 침해사고 대응 방안 및 분석 ····· 19

가. 침해사고 유형별 대응 ····· 19

나. 침해사고 대응 조직 역할 및 책임 ····· 20

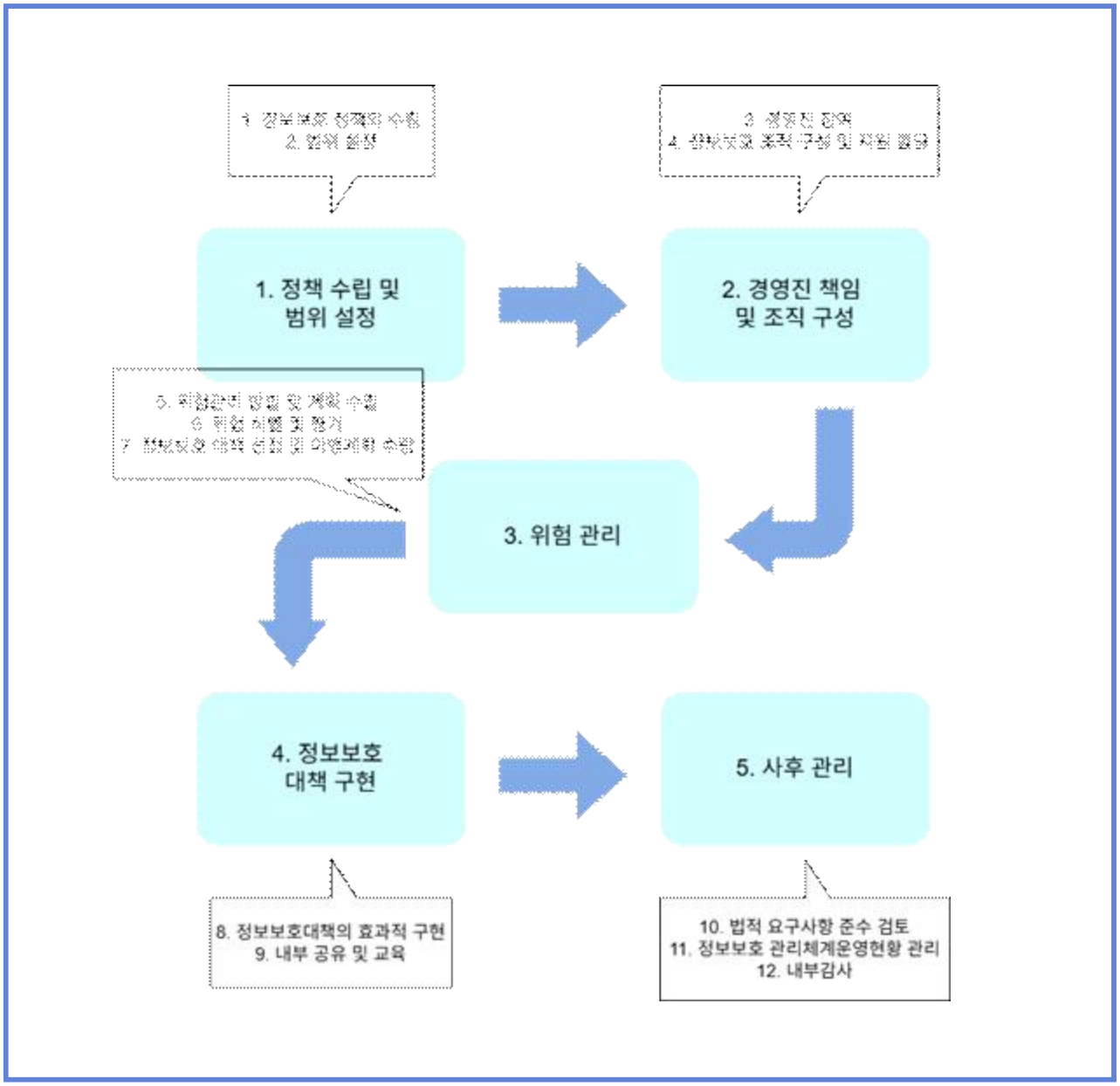
다. Analysis(보안).zip 파일 분석 ····· 21

Ⅸ. 외부 용역 유형에 따른 접근 권한 ····· 27

Ⅹ. 외부 용역에 따른 보안 위협 ····· 28

Ⅺ. 외부자에 대한 주요 통제 강화 방안 ····· 29

Ⅰ. 정보 보호 관리 체계 구축 5단계



Ⅱ. 정보 보호 교육 계획 수립 및 보고 방법

가. 정보보호 계획 수립

1. 연간 정보보호 계획을 수립한다.

교육의 시기 및 기간, 교육 대상, 교육 내용, 교육 방법 등의 내용이 포함된 연간 정보보호 교육 계획을 수립한다.

(1) 정보보호 교육 내용을 정의한다.

정보보호 관련 규정과 정책을 포함하여 교육 내용을 정의한다.

기본 정보보호 교육에는 다음과 같은 내용이 포함되어야 한다.

- 정보보호의 기본 개요
- 정보보호 관련 법률의 이해
- 정보보호 관리 체계 구축 절차 및 방법
- 침해사고 대응 절차 등 임직원이 준수해야 할 정보보호 관련 내부 규정
- 정보보호 규정 위반 시 상벌 규정, 법적 책임 등

(2) 정보보호 교육 내용을 정의한다.

정보보호 교육 대상에는 정보보호 관리 체계 범위 내 정보 자산에 접근하는 정규직 임직원, 임시 직원, 외주 업체 직원 등 모든 인력을 포함한다.

(3) 정보보호 교육 수행 시기 및 시간을 정의한다.

정보보호 교육 대상에게 교육을 수행하기 위한 시기 및 시간을 정의할 때 조직의 업무 특성을 반영하여 업무 영향을 최소화할 수 있는 시점으로 일정을 정의한다.

교육 계획을 수립할 경우에는 관련 법률 규정(정보 통신망 이용촉진 및 정보보호 등에 관한 법률 '개인 정보의 기술적·관리적 보호 조치 기준(고시)' 제3조(내부 관리 계획의 수립·시행) 2항)에 따라 다음과 같은 기준을 준수해야 한다.

구분	대상	교육 방법
기본 정보보호 교육	정규직 임직원, 임시 직원, 외주 업체, 외부자 등을 대상	연 1회 이상
직무별 정보보호 교육	IT 및 정보보호 직무자	연 1회 이상 (기본 정보보호 교육과 별도)
개인 정보보호 교육	개인 정보 관리 책임자 및 개인 정보 취급자	연 2회 이상 (기본 정보보호 교육과 별도)

(4) 정보보호 교육 방법을 정의한다.

정보보호 교육 대상에게 교육의 특성을 고려하여 효율적인 방법을 정의한다.

구분	특징	장점	단점
집체 교육	정해진 시기에 정해진 장소에서 교육을 수행	교육의 효과가 높음	시간 및 공간의 제약이 있음
온라인 교육	인터넷을 통하여 동영상 교육 수행	시간 및 공간의 제약이 없음	교육의 효과가 낮고, 사전에 동영상 촬영 필요
실습 교육	현장에서 업무 기반으로 보안 교육을 수행	다양한 현장 체험으로 교육의 효과가 극대화됨	많은 시간이 필요하고 교육 수행 인원에 제약이 많음

(4) 연간 정보보호 계획을 수립한다.

정보보호 교육 계획은 주로 연말에 수립하여 다음해 상반기에 수행하는 것이 바람직하다.
정보보호 교육 계획은 다음과 같은 내용이 포함되도록 작성한다.

- 교육 시기 (예: 분기별, 반기별 등)
- 교육 기간
- 교육 대상
- 교육 내용
- 교육 방법 (예: 온라인, 집합 교육 등)

나. 정보보호 교육 계획 보고

1. 정보보호 교육 계획을 경영진에게 보고한다.

정보보호 교육 계획을 정보보호 최고 책임자 및 경영진에게 보고를 하여 승인을 받는다.

2. 정보보호 교육 계획을 공유한다.

정보보호 교육 계획을 관련 조직 및 임직원들과 배포하여 공유한다.

구분	대상	교육 방법	교육 시간	교육 일정
기본 정보보호 교육	정규직 임직원, 임시 직원, 외주 용역, 외부자 등을 대상	집체교육	8시간	26년 6월 3일
직무별 정보보호 교육	IT 및 정보보호 직무자	현장교육	16시간	26년 6월 4일 ~ 7일
개인 정보보호 교육	개인 정보 관리 책임자 및 개인 정보 취급자	집체교육	16시간	26년 6월 7일 ~ 9일

Ⅲ. 연간 정보 교육 수행 계획서

1. **1분기 정보보호 교육 계획**
   - **교육 시기:** 2026년 3월
   - **교육 기간:** 2일
   - **교육 대상:** 전 임직원
   - **교육 내용:** 개인정보 보호법 이해, 개인정보 유출 사례 분석, 비밀번호 관리 방법
   - **교육 방법:** 집합 교육

   수행 목표:
   개인정보 보호의 중요성을 인식하고 기본적인 보안 수칙을 준수하도록 한다.

2. **2분기 정보보호 교육 계획**
   - **교육 시기:** 2026년 6월
   - **교육 기간:** 1일
   - **교육 대상:** 서버 및 네트워크 관리자
   - **교육 내용:** 서버 보안 설정, DNS 보안 강화, 메일 서버 취약점 대응
   - **교육 방법:** 실습 중심 교육

   수행 목표:
   시스템 운영자의 보안 설정 능력을 향상시키고 실제 취약점 대응 능력을 강화한다.

3. **3분기 정보보호 교육 계획**
   - **교육 시기:** 2026년 9월
   - **교육 기간:** 2일
   - **교육 대상:** 개발자 및 보안 담당자
   - **교육 내용:** SQL Injection, CSRF, Path Traversal 등 웹 취약점 분석 및 대응
   - **교육 방법:** 온라인 교육 + 실습

   수행 목표:
   웹 애플리케이션 보안 취약점을 이해하고 안전한 개발 환경을 구축하도록 한다.

4. **4분기 정보보호 교육 계획**
   - **교육 시기:** 2026년 12월
   - **교육 기간:** 1일
   - **교육 대상:** 전 임직원
   - **교육 내용:** 랜섬웨어 대응, 피싱 메일 식별, 최신 보안 사고 사례
   - **교육 방법:** 온라인 교육

   수행 목표:
   최신 보안 위협에 대한 대응 능력을 향상시키고 보안 사고 예방 문화를 정착시킨다.

Ⅳ. 교육 결과서 작성

1. 교육 결과

□ **교육내용**
○ 정보보호 관리체계 및 보안 정책 전달
○ 서버 및 네트워크 보안 취약점 점검 방법 교육
○ 웹 애플리케이션 취약점(SQL Injection, CSRF, Path Traversal) 분석 및 대응 방안 교육

□ **참석인원 : 5명**

□ **일정 : 2026년 06월 30일**

□ **장소 : 정보보안 실습실**

2. 상세결과

□ **교육 상세 내용**
○ 정보보호의 개요
- 정보보호의 중요성 및 보안 사고 사례 분석
- 개인정보 보호법 및 정보보호 관련 규정 이해

○ 서버 보안 취약점 점검
- 메일 서버 Open Relay 취약점 점검
- DNS 서버 Recursion 및 Zone Transfer 제한 설정
- 라우터 ICMP 차단 및 IP Spoofing 방지 설정

○ 웹 애플리케이션 보안 취약점 실습
- SQL Injection 공격 원리 및 실습
- CSRF 공격 방식 이해 및 대응 방법
- Path Traversal 취약점 분석 및 접근 제한 방법

○ 보안 대응 방안
- 입력값 검증 및 필터링 적용
- 접근 제어 정책 강화
- 보안 패치 및 정기 점검 수행 방안 수립

□ **교육 일정**

일정	교육 내용	강사
14:00 ~ 15:00	정보보호 개요 및 보안 정책 교육	보안 담당자
15:00 ~ 16:00	메일 서버 및 DNS 서버 보안 점검 실습	시스템 관리자
16:00 ~ 17:00	SQL Injection 및 CSRF 취약점 분석 실습	개발 담당자
17:00 ~ 18:00	보안 대응 방안 및 종합 정리	보안 담당자

□ **교육 결과**

이번 교육을 통해 정보보호의 중요성을 재인식하고 서버 및 웹 애플리케이션 취약점에 대한 이해도를 향상시켰다. 또한 DNS 보안 설정, 메일 서버 취약점 점검, 웹 취약점 대응 방안을 실습함으로써 실제 보안 사고 예방 및 대응 능력을 강화하였다.

V. 정보 보호 점검 계획서 목차 작성

1. 개요

가. 추진 근거

정보통신망의 안정적인 운영과 정보자산 보호를 위해 정기적인 정보보호 점검을 수행한다. 또한 관련 법령 및 내부 보안 정책 준수를 목적으로 한다.

나. 추진 목표

서버, 네트워크, 애플리케이션의 보안 취약점을 사전에 발견하고 개선하여 보안 사고를 예방한다.

가. 일반 현황

현재 운영 중인 주요 정보시스템은 메일 서버, DNS 서버, 웹 서버 및 네트워크 장비로 구성되어 있으며, 내부 중요 정보 및 개인정보를 관리하고 있다.

2. 추진 내용

가. 정보보호 대상 설비 및 시설 현황

- 메일 서버(Postfix)
- DNS 서버(BIND)
- 라우터 및 방화벽
- 웹 서버(Apache)

나. 보유 문서 현황

- 서버 운영 매뉴얼
- 네트워크 구성도
- 계정 관리 대장
- 보안 정책 문서

3. 추진 방법

가. 추진 체계 및 추진 전략

체크리스트 기반 점검을 통해 시스템별 취약점을 분석하고 우선순위에 따라 개선 작업을 수행한다.

나. 진단 수검팀 구성

- 총괄 책임자 1명
- 시스템 관리자 2명
- 보안 담당자 2명

4. 일정 및 예산

가. 정보보호 점검 일정

- 사전 준비: 2026.07.01 ~ 2026.07.03
- 취약점 점검: 2026.07.04 ~ 2026.07.07
- 결과 분석 및 조치: 2026.07.08. ~ 2026.07.10

나. 정보보호 점검 소요 예산

- 보안 솔루션 점검 비용: 500,000원
- 교육 및 실습 비용: 300,000원
- 기타 운영 비용: 200,000원
- 총합: 1,000,000원

5. 기타 사항

점검 과정에서 발견된 취약점은 중요도에 따라 즉시 조치하며, 점검 결과는 문서화하여 차기 보안 계획 수립에 반영한다.

VI. 정보보호 취약점 점검 및 공격기법 분석과 대응방안

가. 정보 보호 취약 요인 사례

구분	점검 항목	설명
웹 애플리케이션	악성 파일 업로드/ 실행 취약점	악성 실행 파일의 업로드/업로드 패스 노출/실행 취약점으로 공격자가 악성 코드를 업로드하여 실행
	부적절한 쿠키/ 세션 관리 취약점	쿠키 내의 사용자 인증 정보 및 자격 증명 정보보호 미흡, 예측 가능한 취약한 세션 ID 사용 취약점으로 사용자의 세션을 가로채어 악용
	취약한 공개 소프트웨어 사용	부적절한 공개 소프트웨어 사용에 의한 취약점으로, 공격자가 공개 소프트웨어의 알려진 취약점을 이용
	인젝션 취약점	입력한 데이터가 명령어나 질의 문의 일부분으로 인터프리터에 전송 취약점으로, 공격자가 임의의 명령어를 실행
	XSS (Cross Site Scripting) 취약점	콘텐츠를 검증 절차나 암호화없이 사용자가 제공하는 데이터를 애플리케이션이 받아 들여 웹 브라우저로 전송하는 취약점을, 악성 스크립트를 공격자가 사용자의 호스트에서 실행
	URL 접속 제한 실패	권한 없는 사용자에게 애플리케이션이 연결 주소나 URL에 접근을 허용하는 취약점으로, 공격자가 취약한 URL에 직접 접속하여 악용
	불안전한 암호화 저장/통신	데이터를 암호화 기능을 거의 사용하지 않는 취약점으로, 공격자가 중요 정보에 접근
	부적절한 오류 처리	애플리케이션 에러를 통하여 의도하지 않게 자신의 구성 정보등 정보를 누출하는 취약점으로, 공격자가 에러 정보를 분석하여 공격에 활용
웹 서버	업로드 디렉터리 실행 권한 점검	악성 실행 파일의 업로드/업로드 패스 노출/실행 취약점으로, 악성 코드를 업로드하여 실행
	디렉토리 리스팅	브라우저에서 서버의 디렉터리 내용을 확인할 수 있는 취약점, 소스 파일 구조, 백업 파일, 문서 파일 등이 노출
	애플리케이션 버전 정보 노출	애플리케이션의 버전 정보가 노출되는 취약점이며, 공격자가 알려진 취약점을 공격
	서비스 소유자 권한 취약점	서비스가 관리자 권한으로 실행되고 있을 경우, 공격자가 시스템 명령 실행 등의 공격이 가능
	에러 메시지 관리	응용 서버는 오류가 발생하였을 때 서버 정보 등을 노출하며, 공격자가 노출 정보를 활용
	HTTP 메소드 취약점	GET, POST 이외의 다른 HTTP 메소드를 지원하는 경우, 악의적인 공격자가 임의의 파일을 업로드하거나 삭제 가능
	샘플 및 테스트 페이지 존재	기본적으로 설치되는 샘플파일들의 정보가 노출
	취약한 웹서버 사용	취약한 버전의 웹 서버로 운영되는 경우, 알려진 취약점을 이용한 공격 발생
DBMS	DBA 관리자 권한 제한 점검	부적절한 DB 권한 설정으로 일반사용자가 DBA 권한을 오용
	불필요한 계정 점검(디폴트 계정 등)	비인가자가 DBMS에 접근하여 데이터를 열람, 수정, 삭제할 수 있는 문제점 발생
	취약한 패스워드 점검	유추 가능한 패스워드 사용하는 취약점
	DB 서비스 보안 설정 점검	보안 설정이 취약한 경우, DB 시스템 정보 등이 노출
	서비스 사용 제한	인증 및 접근 제어가 부적절한 경우 비인가 접근 시도 및 정보 노출 등이 발생
	불필요한 DATA 제거	비인가자가 불필요한 DB에 접근하여 중요 정보를 획득

나. 정보보호 점검 항목

단계	영역	점검 항목
요구 정의 단계	정보보호 요구사항 정의	정보 시스템 정보보호 요구사항 정의
		정보보호 준거성 정의
		정보보호 위협 정의
		위험 관리 방안 수립
	사전 점검 계획	구축 사업자 평가
		정보 시스템 개발 단계별 정보보호 점검 계획 수립
설계	설계 시 보안 관리 및 평가	설계 보안 요구사항
		설계 시 보안 관리
		개발 환경 보안 설계
	보안 아키텍처 설계	정보 시스템 보안 아키텍처 설계
		네트워크 아키텍처 설계
		데이터베이스 아키텍처 설계
		소스 코드 보안 설계
		데이터 보안 설계
		암호화 및 인증 설계
교육/훈련	개발자 교육/훈련	교육 / 훈련 계획
		교육 / 훈련 프로그램
구현	정보 시스템 구현 환경 보안 관리	구현 환경 보안 관리자
		구현 환경 보안 관리 지침
		개발 도구 보안성
		개발 보안 검증 도구 관리
		구현 환경 주기적 점검
	네트워크 보안 구현	네트워크 장비 및 보안 장비 취약점 관리
		네트워크 보안 점검 수행
		무선 통신 구간 점검
		비인가 무선 AP 접속 차단
		가상 사설망 (VPN)
		트래픽 모니터링

	데이터베이스 보안 구현	데이터베이스 성능 보장
		데이터 무결성
		데이터베이스 보안 관리
	소스 코드 보안 구현	소스 코드 개발 보안
		애플리케이션 사용자 테스트
		실행 코드 분석을 통한 보안성 검증
		코드 서명 검증
	암호화 및 인증 구현	암호화
		인증
	사용자 보안 구현	사용자 저장매체 보안
		사용자 시스템 보안
		단말기 등록, 인증 절차 및 관리 방법
		단말기 악성 코드 대응 보호 조치
		모바일 단말 관리 시스템
시험/테스트	보안 점검 수행	보안 설정 점검
		취약점 점검
		보안 점검 수행
		대책 수립
	정보 시스템 이관	정보 시스템 이관
사후 관리	대응 절차	보안 사고 대응 절차
	대응 체계 구축	업무 연속성 계획
		변경 관리
		데이터 안전성
		주기적 보안 패치
	대응/사후 절차	사고 분석 및 공유
		재발 방지

다. 정보보호 점검 체크리스트 점검 결과

점검 항목	설명	점검 방법	권고 사항	점검 결과
악성 파일 업로드/실행 취약점	악성 실행 파일의 업로드/업로드 패스 노출/실행 취약점이며, 악성코드를 업로드하여 실행할 수 있는 문제점 발생	- 실행 파일 업로드 필터링 점검 - 업로드 경로 노출 여부 점검	화이트 리스트 기반 필터링 사용 권고	양호
부적절한 쿠키/세션 관리 취약점	쿠키 내의 사용자 인증 정보 및 자격 증명 정보보호 미흡, 예측 가능한 취약한 세션 ID 사용 취약점이며, 사용자의 세션을 가로채어 악용하는 문제점 발생	- 쿠키/세션 정보 암호화 점검 - 서버 측에서 쿠키 유효화 검사 여부 점검 - 예측 불가한 복잡한 세션 ID 사용 여부 점검	- 128비트 이상의 강한 암호 알고리즘 사용 - 강한 해시를 사용한 세션 ID 생성	양호
취약한 공개 소프트웨어 사용	부적절한 공개 소프트웨어 사용에 의한 웹 페이지 취약점이며, 공격자가 공개 소프트웨어의 알려진 취약점을 이용하는 문제점 발생	- 공개 소프트웨어 취약점 점검 - 안전한 버전 사용 점검	제로보드취약점, FCKeditdor 취약점 등 점검	양호
인젝션 취약점	사용자가 입력한 데이터가 명령어나 질의 문의 일부분으로 인터프리터에 전송 취약점이며, 공격자가 임의의 명령어를 실행하는 문제점 발생	입력 값 필터링 점검	화이트 리스트 기반 필터링 사용 권고	양호
XSS (cross site scripting) 취약점	입력된 콘텐츠를 암호화나 검증 절차 없이 사용자가 제공하는 데이터를 애플리케이션이 받아 들여, 웹브라우저로 전송하는 취약점이며, 공격자가 악성 스크립트를 사용자의 호스트에서 실행하는 문제점 발생	입력 값 필터링 점검	화이트 리스트 기반 필터링 사용 권고	취약

라. XSS 취약점 공격기법 및 대응방안

1. 공격기법

(1) 저장형 XSS (Stored XSS)

- **개념:** 악성 스크립트가 웹 서버의 데이터베이스(DB), 게시판, 프로필 등에 영구적으로 저장되는 형태입니다.
- **공격 흐름:**
  ① 공격자가 게시판 글에 "<script>stealCookies();</script>"와 같은 악성 코드를 삽입하여 저장합니다.
  ② 일반 사용자가 해당 게시글을 열람합니다.
  ③ 서버가 DB에서 악성 스크립트가 포함된 내용을 읽어 사용자 브라우저로 응답합니다.
  ④ 사용자의 브라우저에서 스크립트가 실행되어 피해를 입습니다.
- **특징:** 가장 위험성이 높으며, 해당 페이지를 방문하는 모든 사용자가 피해 대상이 됩니다.

(2) 반사형 XSS (Reflected XSS)

- **개념:** 사용자 입력값이 서버를 거쳐 응답 화면에 즉시 반사(Reflect)되어 나타나는 취약점입니다. DB에 저장되지 않습니다.
- **공격 흐름:**
  ① 공격자가 악성 스크립트가 포함된 URL(예: http://example.com/search?q=<script>... </script>)을 만들어 피해자에게 이메일이나 피싱 링크로 전달합니다.
  ② 피해자가 링크를 클릭하면 요청이 서버로 전송됩니다.
  ③ 서버는 입력받은 파라미터를 그대로 검색 결과 화면 등에 포함하여 응답합니다.
  ④ 피해자의 브라우저에서 스크립트가 실행됩니다.
- **특징:** 특정 사용자를 타깃으로 한 피싱 공격에 주로 사용됩니다.

(3) DOM 기반 XSS (DOM-based XSS)

- **개념:** 서버를 거치지 않고, 브라우저 측에서 자바스크립트가 DOM(Document Object Model) 환경을 안전하지 않게 조작할 때 발생합니다.
- **공격 흐름:**
  ① URL의 해시값(#)이나 쿼리스트링 처럼 브라우저 내에서 처리되는 값에 악성 스크립트가 포함됩니다.
  ② 브라우저 내의 자바스크립트 코드가 document.location이나 element.innerHTML 등을 통해 이 값을 검증 없이 그대로 DOM에 반영합니다.
  ③ 서버의 개입 없이 사용자의 브라우저 단에서 즉시 스크립트가 실행됩니다.

2. 대응방안

(1) 입력값 검증 및 필터링 (Input Validation)

- 사용자가 입력한 데이터의 길이, 타입, 형식 등을 서버 단에서 검증합니다.
- XSS에 주로 사용되는 특수문자나 키워드(<script>, javascript:, onerror 등)를 화이트리스트 기반(허용된 것만 허용)으로 필터링하거나 차단합니다.

(2) 출력값 이스케이프 (Output HTML Escaping)

- 사용자 입력값을 HTML 본문이나 속성에 출력할 때, 브라우저가 이를 코드가 아닌 단순 문자열로 인식하도록 특수문자를 HTML 엔티티로 변환합니다.
- 변환 예시:

변환 전 (특수문자)	변환 후 (HTML 엔티티)
<	<
>	>
&	&
"	"
'	'

(3) HTML 새니타이징 (HTML Sanitization)

- 게시판 에디터처럼 사용자가 부득이하게 HTML 태그(예: <b>, <i>, <img>)를 입력해야 하는 경우입니다.
- 단순 이스케이프를 하면 태그가 작동하지 않으므로, DOMPurify 나 Lucie XSS Filter 같은 검증된 오픈소스 새니타이징 라이브러리를 사용하여 허용된 안전한 태그·속성만 남기고 위험한 스크립트는 제거해야 합니다.

(4) HttpOnly 쿠키 속성 설정

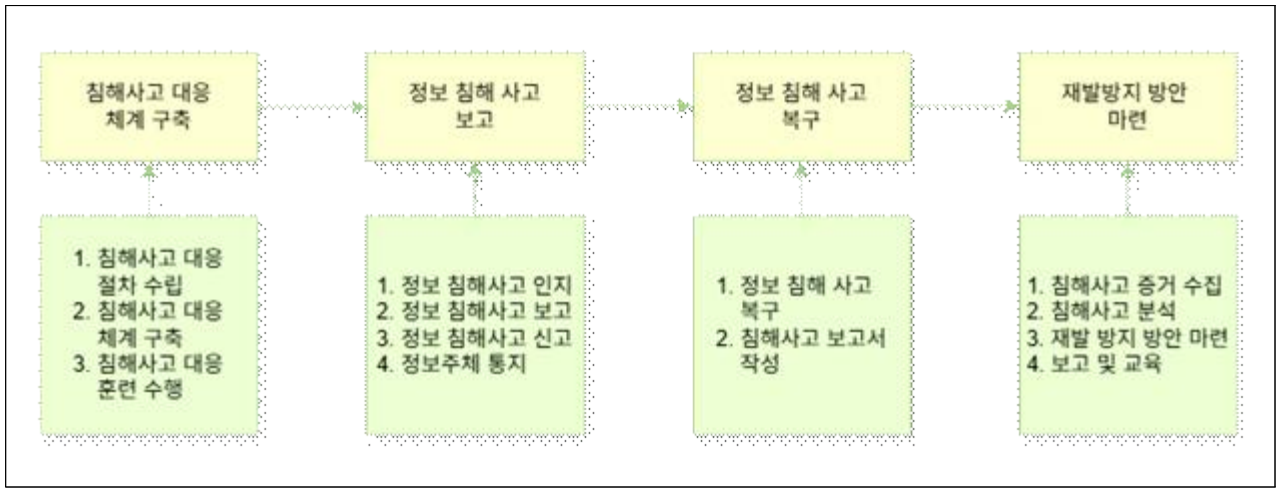
- 세션 ID나 중요한 인증 정보가 담긴 쿠키에 HttpOnly 플래그를 설정합니다.
- 이 설정이 활성화되면 자바스크립트(document.cookie)를 통해서 쿠키에 접근할 수 없으므로, XSS 공격이 성공하더라도 세션 탈취 피해를 방지할 수 있습니다.

(3) 콘텐츠 보안 정책 (CSP, Content Security Policy) 적용

- 웹 서버 응답 헤더에 Content-Security-Policy를 설정하여 브라우저가 실행할 수 있는 스크립트의 출처와 종류를 제한합니다.
- 예를 들어, 인라인 스크립트(<script>...</script>) 실행을 금지하고 허용된 도메인에서 다운로드한 스크립트 파일만 실행하도록 강제할 수 있어 XSS 공격의 실효성을 크게 떨어뜨립니다.

Ⅶ. 정보보호 침해사고 대응 및 개인정보 주체 통보 방법

가. 침해 사고 대응 절차



나. 대응 기관

ㄴ

기관명	홈페이지	전화번호	비고
한국인터넷진흥원 인터넷보호나라	http://www.boho.or.kr	118	민간 보안 사고 접수·처리
국가사이버안전센터	http://www.ncsc.go.kr	111	국가 사이버테러 보안사고 접수·처리
경찰청 사이버범죄신고센터	https://ecrm.police.go.kr	182	사이버 범죄 신고

다. 개인정보 정보주체에게 유출사고를 통보하는 방법

방법	설명	장점	단점
메일	사전에 수집된 이메일 주소로 메일을 발송	통보 메일을 발송하여 동시에 많은 사람들에게 통보 가능	수신 여부에 대한 추가 확인이 필요. 미수신 시 다른 채널을 통한 통보 필요
홈페이지	홈페이지에 개인 정보 유출 사고를 게시	동시에 많은 사람들에게 전달 가능	개인화된 통보기능으로 부적합,다른 채널을 통한 통보가 필요
전화	사전에 수집된 전화번호로 전화를 통하여 통보	수신 및 미수신을 명확하게 식별이 가능하고 명확하게 통보 가능	1:1로 통보를 해야 하므로 시간이 많이 소요
팩스	사전에 수집된 팩스번호로 전화를 통하여 통보	통보 팩스을 발송하여 동시에 많은 사람들에게 통보 가능	수신 여부에 대한 추가 확인이 필요. 미수신 시 다른 채널을 통한 통보 필요

Ⅷ. 정보보호 침해사고 대응 방안 및 분석

가. 침해사고 유형별 대응

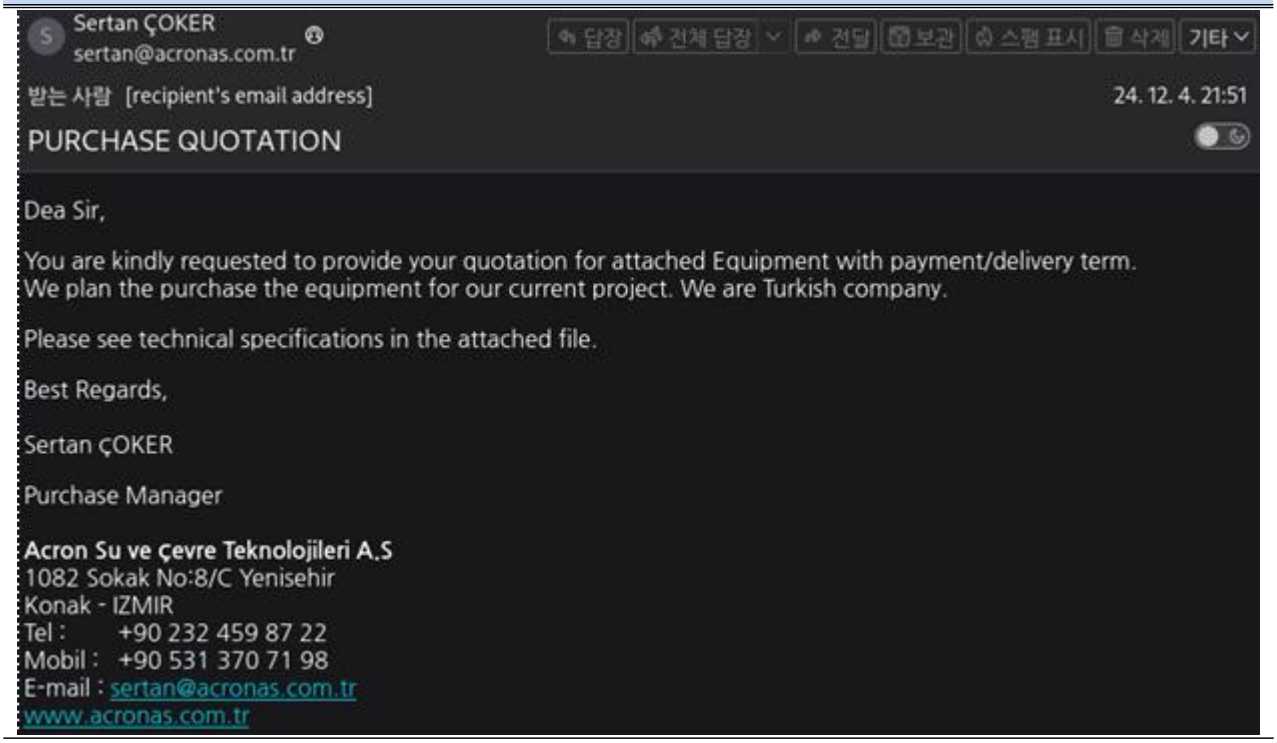
구분	내용
악성코드 공격	1. 악성코드 공격 판단 2. 감염 시스템 분리 및 감염 경로 차단 3. 외부 네트워크와의 연결 차단 4. 미확인 악성코드 대처 및 사고 통보
서비스 거부 공격	1. 서비스 거부 공격 유형 판단 및 추적 차단 2. 정보 통신 서비스 제공자(ISP) 차단 규칙을 통한 차단 및 추적 3. 피해 시스템의 자료 백업 및 보안 취약점 제거 4. 사고 통보
비인가 접근 공격	1. 피해 시스템 격리 또는 관련 서비스 중지 2. 로그 자료 백업 및 비인가 접근 공격에 사용된 계정 제거 3. 사고 통보
복합 구성 공격	1. 사고별 중요도를 판별하여 우선순위에 따라 사고 대응 절차 수행

나. 침해사고 대응 조직 역할 및 책임

구분	내용
정보보안 담당관	- 침해사고 발생 시 대응팀 총괄 - 피해 범위 및 상황 보고서 작성 - 침해사고 발생 시 부문별 관제 센터에 상황 통보 및 기관장 보고 - 국가사이버안전센터(NCSC)에 사고 통보 및 협조 - 침해사고 모의 훈련 주관 및 예방 정책 수립
네트워키 담당	- 이상 징후 발생 시 정보 보안 담당관에게 보고 - 네트워크 장비 상태 확인 후 긴급 조치 수행 - 침해사고 대응 절차에 따라 피해 최소화를 위한 대응 수행 - 침해사고 후 복구 방안 수립 협조 및 복구 수행
보안 장비 담당	- 이상 징후 발생 시 정보보호 실무 책임자에게 통지 - 보안 장비 상태 확인 후 긴급 조치 수행 - 침해사고 대응 절차에 따라 피해 최소화를 위한 대응 수행 - 침해사고 후 복구 방안 수립 협조 및 복구 수행
서버 담당	- 이상 징후 발생 시 정보보호 실무 책임자에게 통지 - 침해사고 대응 절차에 따라 피해 최소화를 위한 대응 수행 - 침해사고 후 복구 방안 수립 협조 및 복구 수행

다. Analysis(보안).zip 파일 분석

1. 메일 내용 분석



Sertan ÇOKER
sertan@acronas.com.tr

답장 | 전체 답장 | 전달 | 보관 | 스팸 표시 | 삭제 | 기타

받는 사람 [recipient's email address]

24. 12. 4. 21:51

PURCHASE QUOTATION

Dea Sir,

You are kindly requested to provide your quotation for attached Equipment with payment/delivery term.
We plan the purchase the equipment for our current project. We are Turkish company.

Please see technical specifications in the attached file.

Best Regards,

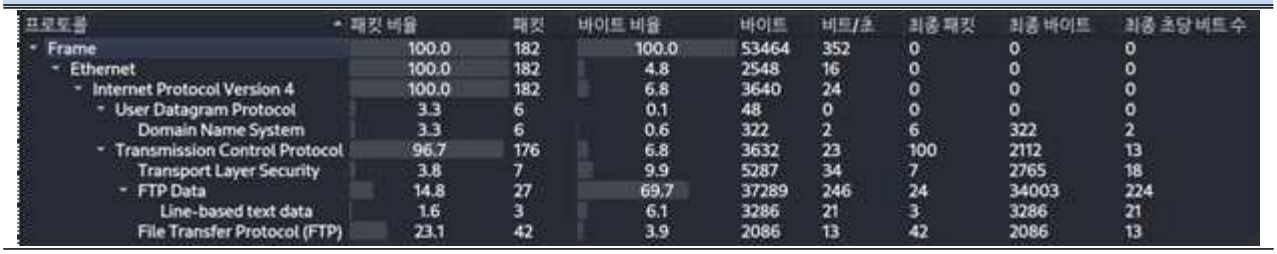
Sertan ÇOKER

Purchase Manager

Acron Su ve çevre Teknolojileri A.S
1082 Sokak No:8/C Yenisehir
Konak - IZMIR
Tel : +90 232 459 87 22
Mobil : +90 531 370 71 98
E-mail : sertan@acronas.com.tr
www.acronas.com.tr

- "현재 프로젝트에 사용할 장비를 구매하려 하니 첨부된 장비의 견적서를 작성해 주세요. 첨부된 파일의 기술 사양을 참조하세요." 라는 문장을 통해 사용자가 첨부파일을 열어보도록 유도하고 있다. (사회공학 기법)
- 특징
  ① 해외 기업을 사칭하여 업무상 신뢰를 유도한다.
  ② 긴급한 구매 요청 형식을 사용한다.
  ③ 첨부파일 확인을 적극적으로 요구한다.
  ④ 프로젝트 진행 중이라는 표현을 사용하여 정상적인 업무 메일처럼 위장하였다.
  ⑤ 첨부파일 실행 이후 악성코드가 실행된 것으로 판단된다.

2. 전송량 통계 분석



프로토콜	패킷 비율	패킷	바이트 비율	바이트	비트/초	최종 패킷	최종 바이트	최종 초당 비트 수
Frame	100.0	182	100.0	53464	352	0	0	0
Ethernet	100.0	182	4.8	2548	16	0	0	0
Internet Protocol Version 4	100.0	182	6.8	3640	24	0	0	0
User Datagram Protocol	3.3	6	0.1	48	0	0	0	0
Domain Name System	3.3	6	0.6	322	2	6	322	2
Transmission Control Protocol	96.7	176	6.8	3632	23	100	2112	13
Transport Layer Security	3.8	7	9.9	5287	34	7	2765	18
FTP Data	14.8	27	69.7	37289	246	24	34003	224
Line-based text data	1.6	3	6.1	3286	21	3	3286	21
File Transfer Protocol (FTP)	23.1	42	3.9	2086	13	42	2086	13

IPv4 기반 환경에서 TCP 및 FTP 관련 트래픽이 패킷 수와 바이트 수 측면에서 압도적인 비중을 차지하고 있음을 확인하였다.

3. 트래픽 분석

Ethernet · 2 | IPv4 · 4 | IPv6 | TCP · 13 | UDP · 4

주소	패킷	바이트	Tx 패킷	Tx 바이트	Rx 패킷	Rx 바이트	국가
10.12.4.1	6	574 바이트	3	341 바이트	3	233 바이트	
10.12.4.101	182	53 kB	87	43 kB	95	10 kB	
172.67.74.152	19	5 kB	10	4 kB	9	944 바이트	
192.254.225.136	157	48 kB	82	6 kB	75	42 kB	

내부 사설 IP 대역(10.12.4.0/24) 및 외부 공인 IP 호스트들을 대상으로 패킷 수와 바이트 수 통계를 집계하여 대량의 트래픽을 유발하는 주요 엔드포인트를 식별하였다.

4. 패킷 1



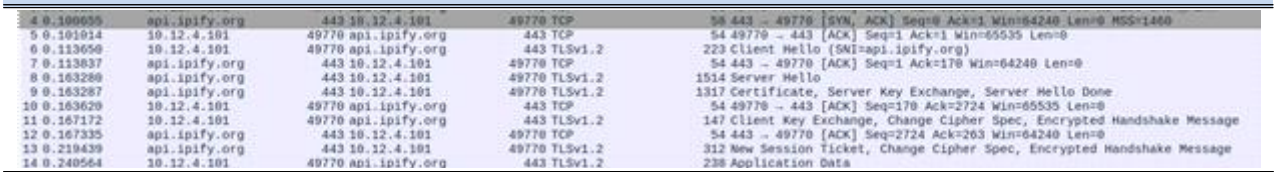
내부 PC가 api.ipify.org의 IP 주소를 질의한다.

5. 패킷 2



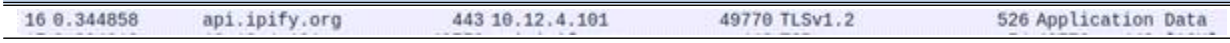
DNS 응답을 통해 api.ipify.org의 IP를 획득한다.

6. 패킷 4~14



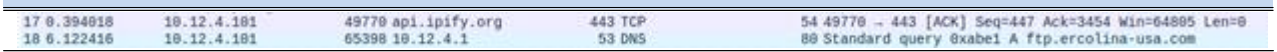
HTTPS 연결을 생성한다.

7. 패킷 16



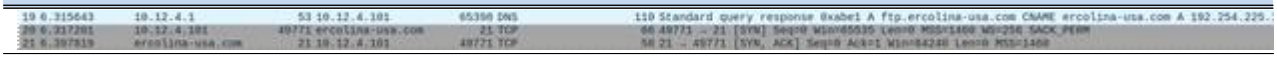
api.ipify.org에 접속하여 자신의 공인 IP를 확인하는 과정이다. 이는 악성코드가 감염된 시스템의 외부 IP를 파악하기 위해 자주 수행하는 행위이다.

8. 패킷 17~18



공격 서버의 IP를 획득하여 공격 서버의 도메인은 ercolina-usa.com 이고, IP는 192.254.225.136 라는 것을 확인하였다.

9. 패킷 19~21



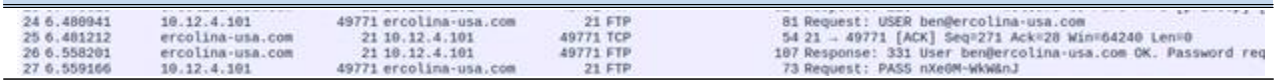
FTP 서버(21번 포트)와 TCP 연결을 생성한다.

10. 패킷 22



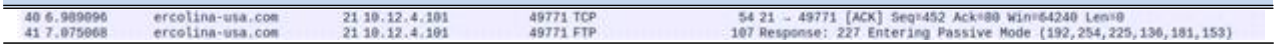
FTP 서버에 접속 성공하였다.

11. 패킷 24



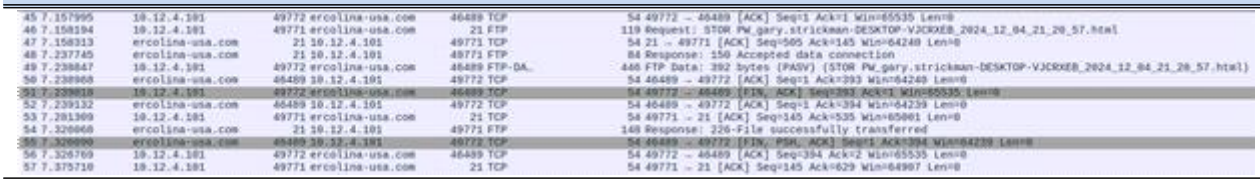
USER ben@ercolina-usa.com 은 FTP 사용자 계정으로 비밀번호를 입력하여 로그인에 성공하였다.
즉, 공격자는 미리 생성한 FTP 계정을 이용하여 데이터를 저장하고 있다.

12. 패킷 40~41



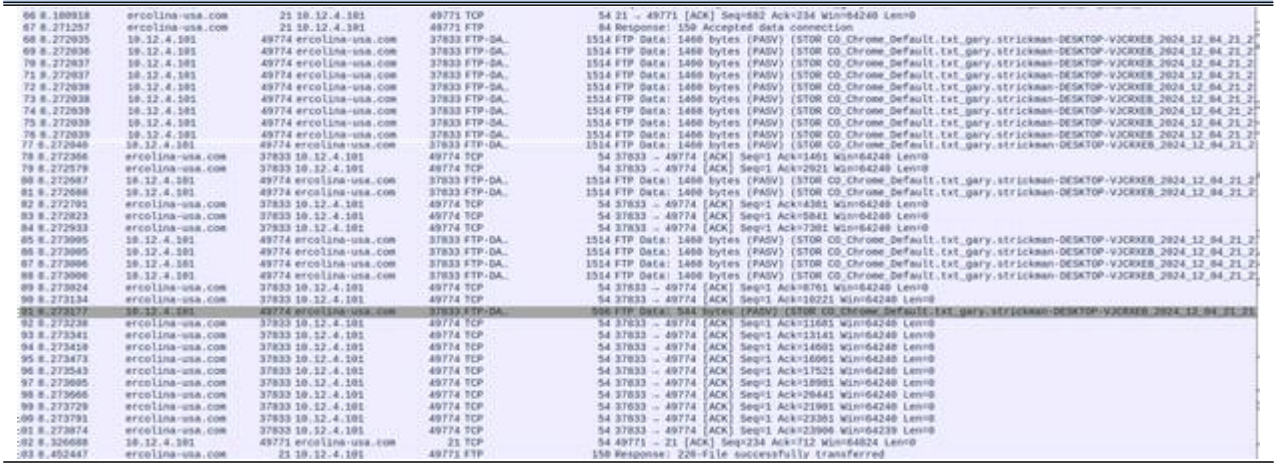
Passive Mode 요청하고 승인하였다.

13. 패킷 45~57



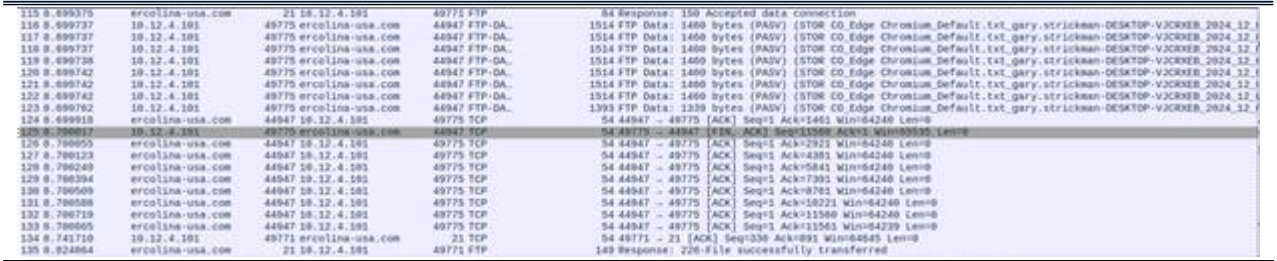
Chrome 정보를 업로드하여 약 1,466 Byte씩 여러 번 실제 파일 데이터가 전송되면서 Chrome 정보가 유출되었다.

14. 패킷 66~103



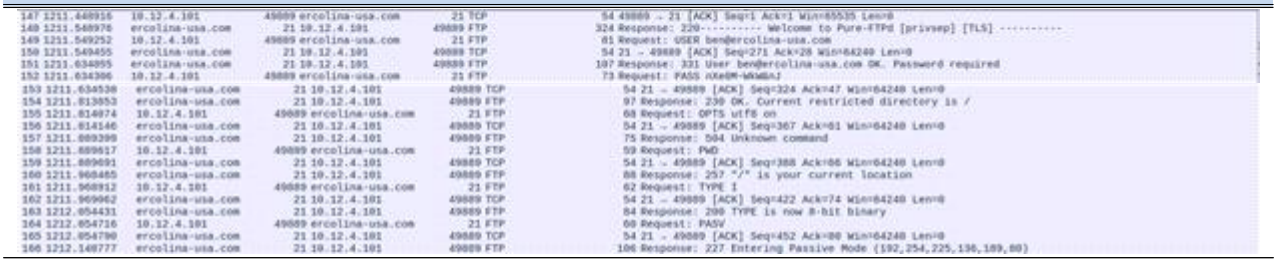
HTML 파일 전송되면서 HTML 정보가 유출되었다.

15. 패킷 113~135



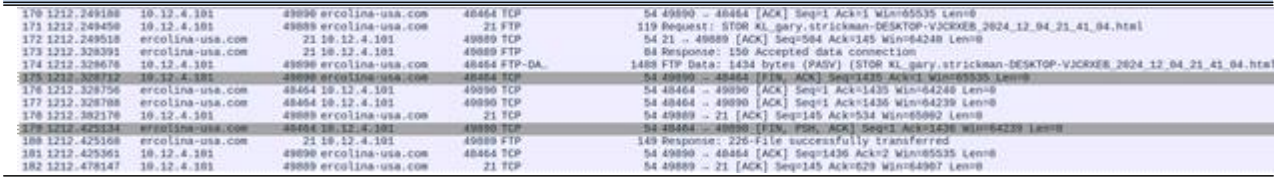
Edge_Default.txt 파일로 Edge 정보가 전송되며 Microsoft Edge 정보 유출되었다.

16. 패킷 150~166



FTP 로그인 재수행하면서 추가 정보가 유출되었다.

17. 패킷 170~182



KL.gary.strickman... 라는 새로운 파일을 업로드 하고 파일이 전송되어 파일 업로드가 완료되며 추가 정보가 유출되었다.

18. 결론

(1) 사고 개요

제공된 이메일과 PCAP 파일을 분석한 결과, 본 침해사고는 견적 요청(Purchase Quotation)을 가장한 스피어 피싱 메일을 이용하여 사용자의 첨부파일 실행을 유도하고, 이후 감염된 시스템의 정보를 외부 FTP 서버로 전송하는 정보 탈취형 악성코드 공격으로 분석되었다.

피싱 메일에는 장비 견적 요청과 함께 첨부파일 확인을 요구하는 내용이 포함되어 있었으며, 사용자가 첨부파일을 실행한 이후 내부 PC(10.12.4.101)는 외부 서버와 지속적으로 통신하며 브라우저 및 시스템 정보를 업로드하는 행위가 확인되었다.

(2) 악성코드 행위 분석

패킷 분석 결과 악성코드는 먼저 패킷 1~16에서 api.ipify.org와 HTTPS 통신을 수행하여 감염 시스템의 공인 IP 주소를 확인하였다.

이후 패킷 17~18에서는 ercolina-usa.com에 대한 DNS 조회를 수행하여 공격자 서버(192.254.225.136)의 IP 주소를 획득하였다.

공격 서버 확인 후 패킷 19~22에서 FTP 연결을 생성하고, 패킷 24~27에서는 USER, PASS 명령을 이용하여 FTP 로그인을 수행하였다.

로그인 이후 패킷 45, 66, 113, 172에서는 STOR 명령을 이용하여 Chrome, Microsoft Edge 및 Desktop 관련 정보를 포함하는 파일을 업로드하였다. 각 파일 전송 후 패킷 58, 103, 135, 180에서는 226 File successfully transferred 응답이 확인되어 파일이 공격자 서버에 정상적으로 저장되었음을 확인하였다.

업로드된 파일명에는 사용자 계정(gary.strickman), 컴퓨터 이름(DESKTOP-VJCRXEB), 날짜와 시간 정보가 포함되어 있어 감염된 시스템의 사용자 환경 정보가 함께 유출된 것으로 분석된다.

(3) 공격 흐름

① 사용자가 피싱 메일을 수신한다.
② 첨부파일을 실행하여 악성코드가 감염된다.
③ 악성코드는 api.ipify.org를 통해 공인 IP를 확인한다.
④ ercolina-usa.com의 IP를 조회한다.
⑤ FTP 서버에 로그인한다.
⑥ Chrome, Edge 및 시스템 정보를 수집한다.
⑦ STOR 명령을 이용하여 공격자 서버로 파일을 업로드한다.
⑧ 226 File successfully transferred 응답을 수신하며 정보 유출이 완료된다.

(4) 침해사고 대응 방안

① 이메일 보안 솔루션을 통해 첨부파일 및 URL에 대한 악성 여부를 검사하고, 의심스러운 메일은 격리한다.
② 출처가 불분명한 첨부파일은 실행하지 않도록 사용자 보안 교육을 실시한다.
③ 백신 프로그램 및 EDR(Endpoint Detection & Response)을 최신 상태로 유지하여 악성코드 실행을 탐지·차단한다.
④ 방화벽 및 IPS를 이용하여 FTP(21번 포트)와 같은 불필요한 외부 통신을 제한하고, 비정상적인 파일 업로드를 모니터링한다.
⑤ DNS 및 네트워크 로그를 지속적으로 모니터링하여 비인가 서버와의 통신을 탐지한다.
⑥ 운영체제와 브라우저를 최신 보안 패치 상태로 유지하여 악성코드 감염 가능성을 최소화한다.
⑦ 감염이 확인된 시스템은 즉시 네트워크에서 격리하고, 포렌식 분석 후 악성코드를 제거하며 계정 비밀번호를 변경한다.

IX. 외부 용역 유형에 따른 접근 권한

IT 외부 용역 유형		용역 특성				
		접근 IT 자원		자원 사용 권한		접근 경로
유형 1	운영 용역	내부 데이터	O	읽기	O	온라인
		IT 시스템	O	쓰기	O	
유형 2	유지 보수 용역	내부 데이터	O	읽기 (내부 직원 동행)	X (O)	온라인
		IT 시스템	O	읽기 (내부 직원 동행)	X (O)	
유형 3	SI 용역	내부 데이터	O	읽기	O	온라인
		IT 시스템	O	쓰기	X	
유형 4	데이터 처리 용역	내부 데이터	O	읽기	O	온라인
		IT 시스템	X	쓰기	X	
유형 5	오프라인 지원	내부 데이터	O	읽기	O	온라인
		IT 시스템	X	쓰기	X	

X. 외부 용역에 따른 보안 위협

구분	점검 항목
물리적 접근 영역	- (접근 통제) 비인가자가 침입하거나, 인가받은 자가 업무 외의 목적으로 정보를 열람하는 경우에 의한 중요 정보 유출 - (출입 탐지) 비인가자 출입 탐지를 위한 CCTV의 사각 지대 존재 - (출입 관리) 전산실 등 중요 정보가 존재하는 장소에 출입 통제하지 않아 중요 정보에 불법적인 접근 위협 - (반입 매체 통제) 허가되지 않은 매체 반·출입으로 인한 악성 코드 감염 또는 정보 유출
기술적 접근 영역	- (인증 수단) 정보 시스템 접근 시 ID/PW만을 사용할 경우 노출되는 패스워드 설정 등으로 인한 침해 요소 - (인증 정보) 외주 개별 인력에 내부 시스템 사용자 인증 정보를 제공해 주지 않아 사후관리 불가 위협 - (네트워크 통제) 업무 수행 중 외부망에 접속하여 악성 코드 감염 취약점이 발생하여 시스템파괴 내부 정보를 외부로 유출할 위협이 존재 - (출력물 통제) 중요 문서를 출력하여 유출할 위험 - (반출 매체 통제) 직원 출입 시 노트북, USB 등에 대한 매체 통제 미이행
관리적 접근 영역	- (체계적 인력 관리 계획) 체계적인 인력 관리 계획 미흡하여 정보 시스템 불법 접근 정보 유출등에 대한 빠른 추적이 불가능 - (인력 배치) 업무에 적합하지 않은 상주 유지 보수 인력 배치로 중요 정보 유출 - (인력 감사) 인력에 대한 감사를 실시하지 않아 중요 정보 유출의 가능성 존재 - (접근 권한) 중요 정보 접근에 대한 관리가 부재로 허가받지 않은 정보에 접근을 시도하거나 접근허가가 만료된 계정을 이용한 시스템에 접근 및 중요 정보 유출

Ⅺ. 외부자에 대한 주요 통제 강화 방안

1. 외부자에 대한 보안 통제 내역

외부자에 대한 보안 통제 활동을 관리적, 물리적, 기술적 관점엣 주요 통제 내역을 정리하여 관리한다.

구분	정보보호 활동	세부 내용
물리적 보안 영역	물리적 접근 통제	- 외부자의 정보 시스템 접근 통제 - 접근 유형 및 접근 사유 파악 - 제한 구역, 접견 구역, 장비 출하 구역 등에 대한 보안 조치와 절차 수립
	출입 이력 관리	- 출입 일시, 방법과 범위 등을 문서화
	이동 매체 반출·입 통제	- 반출·입되는 이동 매체에 대한 파악 - 이동 매체의 반출·입 과정 문서화 - 반출·입 이동 매체의 보안 검사
관리적 보안 영역	작업 내역 관리	- 외부자의 내부 시스템 접근 기록 상시 감독 - 저장 매체 사용 방지 조치
	시스템 접근 권한 관리	- 시스템 접근 권한 정의 및 개별 부여
	정보 시스템 관리	- 정보화 장비의 반입 전 초기화/점검, 보안 SW 설치 - 외부자에 대한 보안 정책 수립 및 이행
기술적 보안 영역	접근 관리	- 내부 시스템에 대한 접근 이력 관리 시스템 운영 - 내부 시스템에 접근 시 두 가지 이상의 방법으로 사용자 인증 - 내부 시스템에 접근하는 기기에 대하여 사전 점검
	출력물 유출 관리	- 비공개 자료 출력 시 출력자, 출력IP, 출력 일시 등을 기록
	네트워크 제한	- 외부망과 물리적 분리 - 내부 운영 시스템 별 논리적 망 분리 운영
	반출·입 매체 관리	- 반출·입 매체의 악성 코드 검사 - 외주 업무의 특성에 따라 반출·입 매체의 제한 점검

2. 외주 용역 수행 단계별 주요 정보보호 활동

외부자에 대한 보안 통제 활동을 용역 수행 각 단계별로 주요 통제 내역을 정리하여 관리해야 한다.

구분	정보보호 활동	세부 내용
입찰 및 계약 단계	보안 요구 기준 마련	외주 용역 추진에 필요한 정보보호 요구사항 수준 등 기준을 마련하고 확인
	보안을 고려한 계약 체결	정보보호 요구사항을 충족하는 사업자 선정, 필요한 경우에는 기술 협상 과정에서 정보보호 요구사항을 반영
개발 및 구축 단계	자료에 대한 보안 관리	자료 관리에 관한 보안 계획을 수립하여 정보보호 및 내부 정보가 유출되는 것을 방지
	사무실 장비에 대한 보안 관리	외주업체 사무실의 물리적 보안 조치를 확인하고 반출·입하는 장비에 대한 보안 관리 계획을 수립하고 이행
	내·외부망 접근 관리	외부자의 내부 시스템 접근에 대한 관리 및 외부망 접근 제어
	외부자 신원 조회	외부자를 통한 정보 유출을 막기 위해 보안 서약서 작성 및 사전 신원 조사 실시
사업 완료 단계	사업 완료 시 보안 대책	최종 산출물 중 보안이 요구되는 자료의 유출 방지를 위해 보호 조치를 실시